Джафарлі. Рев`ю “DeepOP: A Hybrid Framework”

Фарід Джафарлі · Advanced Security Architecture and Engineering · Наукова публікація 1

1. Вступ

Стаття «DeepOP: A Hybrid Framework for MITRE ATT&CK Sequence Prediction via Deep Learning and Ontology» (Shuqin Zhang, Xiaohang Xue, Xinyu Su; Electronics, 2025) присвячена прогнозуванню багатокрокових APT-атак, зокрема в середовищах IIoT, де IDS та ADS дають багато хибних спрацювань і реагують із запізненням. Автори хочуть передбачати, які техніки ATT&CK супротивник застосує далі, щоб захисники могли діяти на випередження.

2. Методологія

Фреймворк має чотири етапи. Спочатку збирають CTI: близько 1500 звітів з експертною розміткою ATT&CK (17 302 пари «опис → техніка», покриття 93,2 % технік) і близько 2200 сирих звітів за 2006-2024 роки. Далі витягують знання: перенавчена модель rcATT розпізнає понад 200 технік замість приблизно 100, IoC шукають регулярними виразами, а інструмент Extractor спирається на семантичну розмітку ролей. Третій етап становлять онтологія COASE (тактика, техніка, IoC, атакувальник, актив, артефакт, інструмент) і шість правил SWRL, які виводять причинно-наслідкові зв’язки між техніками та відокремлюють паралельні шляхи атаки. На четвертому етапі працює encoder-decoder на базі Transformer, де в декодері звичайну увагу замінено на causal window attention (CWA): голови уваги поділено на групи з вікнами різного розміру та причинною маскою, тому складність лінійна.

Модель навчали з Adam, поділом 8:1:1, grid search і early stopping. Метрики: accuracy, precision, recall, F1. Для порівняння взяли LSTM (DeepAG), GRU, байєсівську мережу, а для абляції звичайний Transformer.

3. Результати

DeepOP досягає F1 = 0,894 (recall 0,978, precision 0,822). Для порівняння: у LSTM 0,865, у Transformer без CWA 0,861, у GRU 0,835, у байєсівської мережі 0,614. На горизонті шести кроків F1 DeepOP падає лише до 0,767, у LSTM до 0,647. Якщо пропущено 60 % детекцій, DeepOP зберігає F1 = 0,526, у конкурентів від 0,272 до 0,452. На кейсі Frankenstein онтологія розділила два паралельні ланцюги атаки, а базовий метод BAN злив їх в одну послідовність.

4. Ключові інсайти

- Ланцюг атаки точніше будувати за причинними зв’язками, ніж за порядком тактик. Впорядкування технік за колонками ATT&CK спотворює реальні атаки, а зв’язки через спільні активи, артефакти та IoC точніші. У моделюванні загроз я будуватиму ланцюги технік на DFD саме через спільні активи.
- ATT&CK підходить як спільна мова для CTI, моделі та SOC. Прогноз у вигляді конкретних T-ID можна одразу накласти шаром на ATT&CK Navigator і насамперед готувати детекції та мітигації (D3FEND) там, де атака найімовірніше продовжиться.

- Інструменти виявлення варто перевіряти на стійкість до пропусків телеметрії. SOC ніколи не бачить усіх кроків атаки, тому тест із пропуском від 0 до 60 % подій я застосовуватиму як критерій під час вибору будь-якого з них.

5. Висновок

Основні внески роботи: онтологія COASE, датасет причинно пов’язаних APT-послідовностей і механізм CWA, що покращує довгострокове прогнозування. Водночас датасет надається лише на запит, онтологічний модуль перевірено на одному кейсі, спосіб усереднення precision і recall не описано, а матрицю ATT&CK for ICS не використано, хоча фокус статті на IIoT. Автори планують розширити датасет, додати онлайн-прогнозування на потокових даних і застосувати методи причинного висновування та доменної адаптації.